

Kelp DAO安全事件总结

事件概述：

4月18日 KelpDAO 遭受约 2.9 亿美元攻击，初步判断为高度复杂的国家行为者（疑似朝鲜 Lazarus Group 下属 TraderTraitor）所为。此次攻击完全孤立于 KelpDAO 的 rsETH 配置，系其采用单 DVN (Decentralized Verifier Network) 设置所致。LayerZero 协议本身未被利用，无任何其他跨链资产或应用受到波及。攻击核心是黑客通过污染 LayerZero DVN 依赖的下游 RPC 基础设施，获取了 DVN 使用的 RPC 节点列表，并入侵了两个独立 RPC 节点，替换了 op-geth 二进制文件，并使用自定义 payload 伪造消息，只对 DVN 显示假数据，对其他 IP（包括 LayerZero Scan）显示真实数据。之后黑客通过 DDoS 攻击未被入侵的 RPC，触发故障转移到已投毒的 RPC，使得假消息被接受从而完成攻击。攻击完成后，黑客删除了恶意的二进制文件、日志与配置。目前 LayerZero 已废弃所有受影响 RPC 节点并完成替换，DVN 已恢复正常运行。

op-geth 二进制文件

op-geth 二进制文件是 **Optimism (OP Stack)** 架构中的核心执行客户端 (Execution Client)。它是以太坊 **Go-Ethereum (Geth)** 的一个定制化分支，专门用于处理以太坊 **Layer 2 (L2) Rollup** 的交易执行、状态管理和智能合约逻辑。

以下是关于 op-geth 二进制文件的详细说明：

- 定义:在 OP Stack 架构中, `op-geth` 负责接收、排序和执行来自于 `op-node` (共识层) 的交易, 更新状态树, 维护与 Geth 兼容的 JSON-RPC 接口。
- 功能与作用:
 - 独立二进制文件:它是一个无状态(在节点运行层面上)的二进制文件, 直接进行编译构建。
 - 处理交易:它专门负责处理 Optimism L2 上的用户交易。
 - 状态验证:它通过执行 L1 传来的 Rollup 数据来同步和验证链上状态。
- 与 Geth 的关系:`op-geth` 基于 Geth 修改, 旨在兼容以太坊虚拟机 (EVM), 但调整了区块生产和状态处理规则以适应 L2 场景。
- 与其他组件的交互:通常与 `op-node` 配合使用, `op-node` 驱动 `op-geth` 进行区块合成。

总的来说, `op-geth` 是 Optimism Rollup 节点中执行业务逻辑的那个可执行程序, 直接决定了 L2 链的账本状态。

总结:

1. 拿到供应商LayerZero的两个独立 RPC 节点的Root权限(大概率是内鬼或者离职员工干的);
2. 然后替换了 `op-geth` 二进制文件, 并使用自定义 payload 伪造消息, 只对 DVN 显示假数据;
3. 用DDOS把剩余的RPC节点打崩;(这样后续验证全部都会走那两台肉鸡);
4. 通过验证后, 可以成功拿到kelp的再质押凭证rsETH;
5. 拿rsETH去AAVE之类的借贷平台贷出ETH!